Aurora - Banca Digital

Propietario: Jeffrey Hurtarte
Revisor: Saul Orozco
Colaboradores:
Generado en fecha: Fri Oct 09 2026

Resumen Ejecutivo

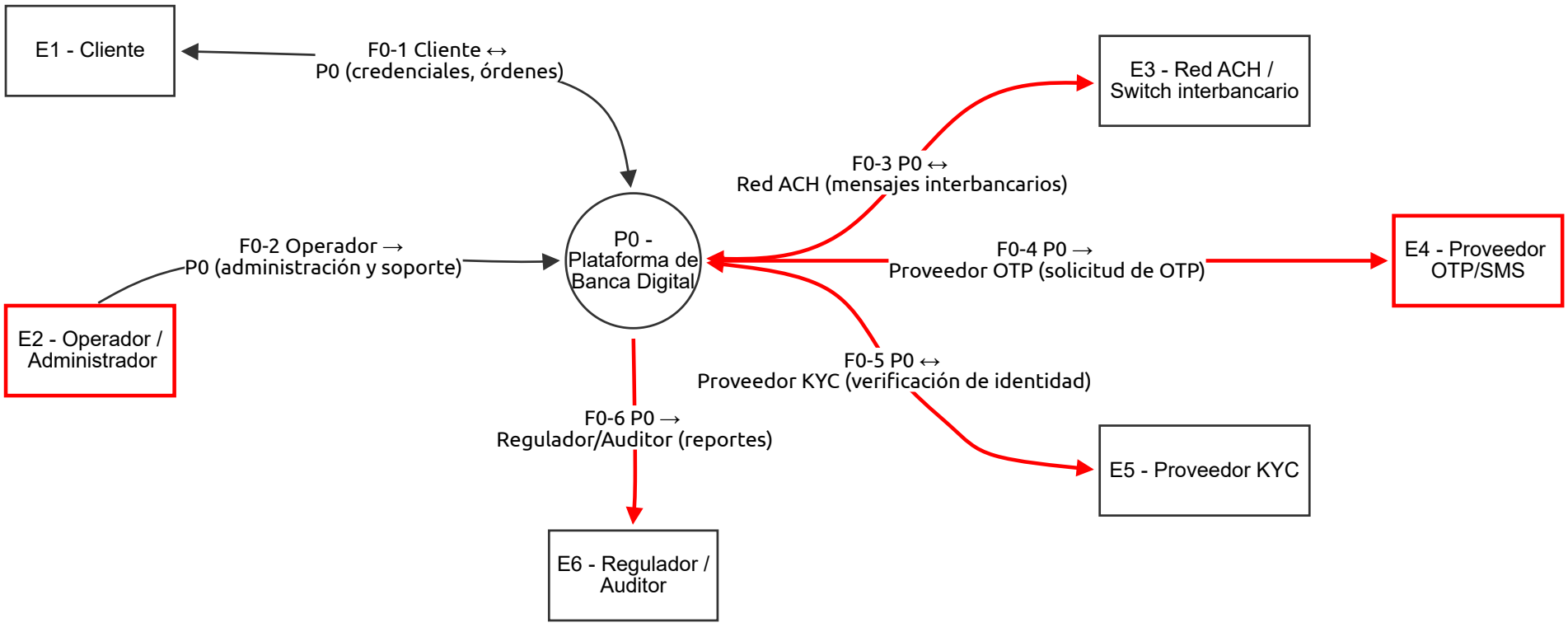
Descripción de alto nivel del sistema (high level system)

Plataforma de banca digital que permite a clientes consultar saldos, realizar transferencias y pagar servicios mediante una aplicación web y una aplicación móvil. Los canales se conectan por un API Gateway a servicios de autenticación, cuentas y transacciones. Un middleware de mensajería integra el core bancario y la red ACH. Se apoya en proveedores externos de OTP/SMS y verificación de identidad (KYC).

Resumen

Total amenazas	24
Total amenazas mitigadas	0
No Mitigadas	24
Abierto / Crítica Prioridad	5
Abierto / Alta Prioridad	9
Abierto / Prioridad Media	7
Abierto / Baja Prioridad	3

DFD Nivel 0 - Contexto



DFD Nivel 0 - Contexto

P0 - Plataforma de Banca Digital (Proceso)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

E1 - Cliente (Actor)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

F0-1 Cliente ↔ P0 (credenciales, órdenes) (Flujo de datos)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

F0-3 P0 ↔ Red ACH (mensajes interbancarios) (Flujo de datos)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
8	T-21 [Medio] Alteración o suplantación de mensajes con la red ACH	Tampering / Manipulación	Media	Abierto	4	Un atacante altera o suplanta mensajes interbancarios.	C-11 segmentación; C-15 mensajería firmada, idempotencia y anti-replay

F0-2 Operador → P0 (administración y soporte) (Flujo de datos)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

F0-6 P0 → Regulador/Auditor (reportes) (Flujo de datos)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
9	T-24 [Bajo] Reportes de auditoría con PII sin controles	Information disclosure / Brecha de información	Baja	Abierto	2	Los reportes exportados contienen PII sin controles de acceso ni enmascaramiento.	C-16 logging con enmascaramiento, exportación segura con control de acceso

F0-4 P0 → Proveedor OTP (solicitud de OTP) (Flujo de datos)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
5	T-25 [Bajo] Saturación del proveedor SMS	Denial of service / Denegación de servicio	Baja	Abierto	1	Saturación o caída del proveedor impide la entrega de OTP.	C-19 gestión de terceros y SLA, C-20 resiliencia

F0-5 P0 ↔ Proveedor KYC (verificación de identidad) (Flujo de datos)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
7	T-12 [Alto] Brecha en proveedor KYC que expone documentos de identidad	Information disclosure / Brecha de información	Alta	Abierto	8	Un incidente en el proveedor expone documentos de identidad y PII de clientes.	C-07 cifrado y tokenización, C-19 evaluación y contratos con el proveedor, minimización de datos enviados

E2 - Operador / Administrador (Actor)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
10	T-20 [Medio] Suplantación de operador por credenciales compartidas	Spoofing / Spoofing	Media	Abierto	4	Uso de credenciales compartidas permite suplantar a un operador.	C-01 MFA y vinculación de dispositivo, C-14 PAM y segregación de funciones

E3 - Red ACH / Switch interbancario (Actor)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

E4 - Proveedor OTP/SMS (Actor)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
2	T-08 [Crítico] Intercepción de OTP por SIM swap o malware	Spoofing / Spoofing	Crítica	Abierto	9	Un atacante intercepta el OTP enviado por SMS mediante cambio de SIM, malware o phishing y autoriza operaciones.	C-01 MFA resistente a phishing y vinculación de dispositivo, C-17 SIEM/UEBA, migrar OTP por SMS a push/TOTP/FIDO2

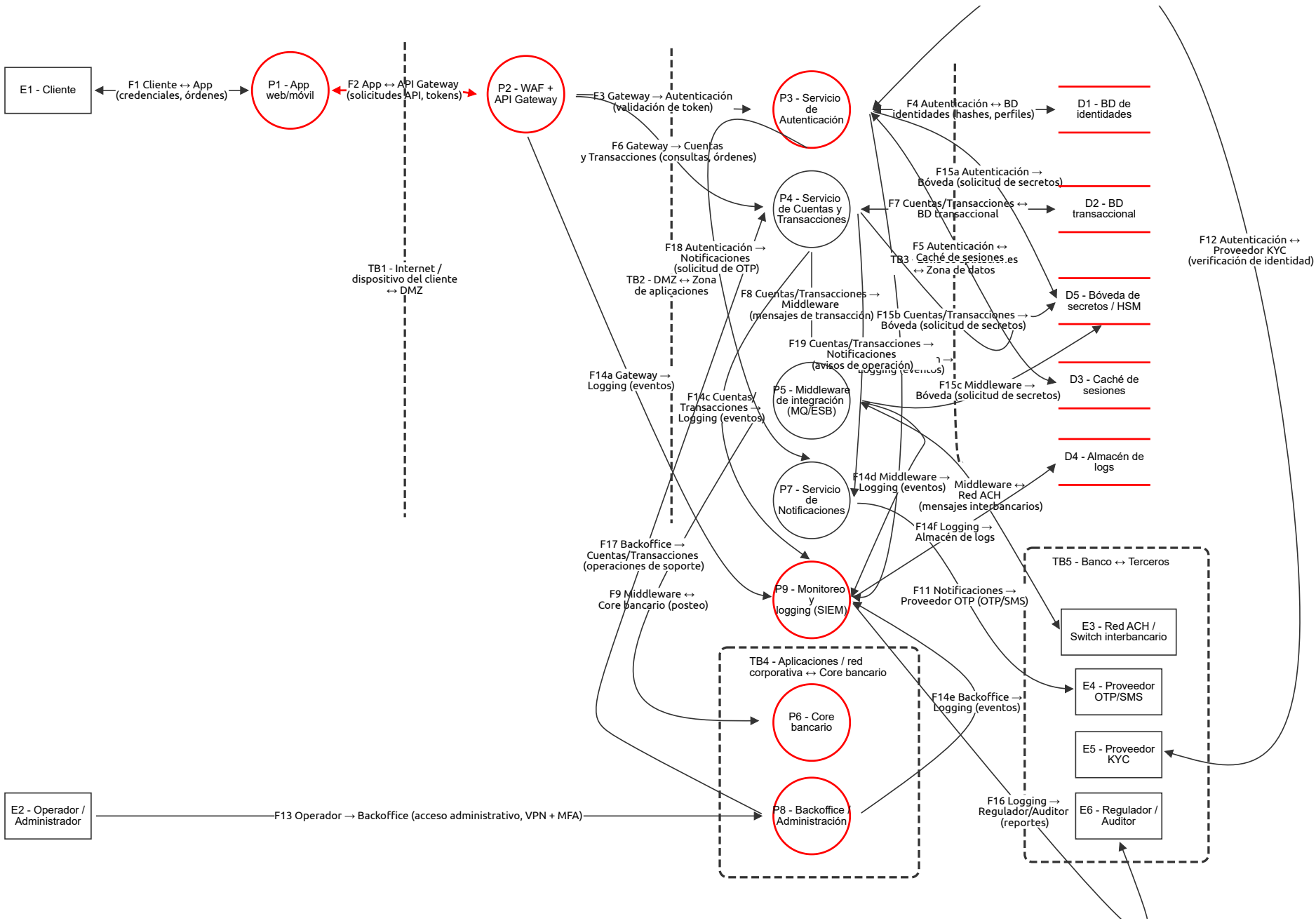
E5 - Proveedor KYC (Actor)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

E6 - Regulador / Auditor (Actor)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

DFD Nivel 1 - Procesos



DFD Nivel 1 - Procesos

E1 - Cliente (Actor)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

E2 - Operador / Administrador (Actor)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

E3 - Red ACH / Switch interbancario (Actor)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

E4 - Proveedor OTP/SMS (Actor)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

E5 - Proveedor KYC (Actor)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

E6 - Regulador / Auditor (Actor)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

P1 - App web/móvil (Proceso)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
25	T-15 [Alto] App reempaquetada o SDK de terceros comprometido	Tampering / Manipulación	Alta	Abierto	6	Una app clonada o un SDK comprometido ejecuta código malicioso en el dispositivo del cliente.	C-06 attestation y ofuscación, C-12 SCA y SBOM, C-19 gestión de terceros
30	T-23 [Medio] Datos sensibles en almacenamiento local o capturas de pantalla	Information disclosure / Brecha de información	Media	Abierto	4	La app guarda o expone datos sensibles en el dispositivo (almacenamiento local, capturas, portapapeles).	C-06 protección en la app (ofuscación y attestation)

P2 - WAF + API Gateway (Proceso)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
16	T-10 [Alto] DDoS o scraping por ausencia de rate limiting	Denial of service / Denegación de servicio	Alta	Abierto	6	Tráfico volumétrico o de capa 7 degrada o interrumpe el canal digital.	C-09 rate limiting, anti-bot, WAF y anti-DDoS, C-20 resiliencia
28	T-19 [Medio] Errores verbosos y cabeceras que revelan tecnología	Information disclosure / Brecha de información	Media	Abierto	3	Mensajes de error y cabeceras revelan versiones y detalles internos que facilitan ataques.	C-03 validación y manejo de errores, C-10 seguridad del API Gateway, C-12 hardening

P3 - Servicio de Autenticación (Proceso)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
11	T-01 [Crítico] Toma de cuenta por credential stuffing, phishing en tiempo real o MFA débil	Spoofing / Spoofing	Crítica	Abierto	16	Un atacante accede a cuentas legítimas con credenciales reutilizadas, phishing en tiempo real o un segundo factor débil.	C-01 MFA resistente a phishing y vinculación de dispositivo, C-02 gestión de sesiones, C-09 rate limiting y anti-bot, C-17 SIEM/UEBA, C-18 antifraude

P4 - Servicio de Cuentas y Transacciones (Proceso)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

F1 Cliente ↔ App (credenciales, órdenes) (Flujo de datos)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

F2 App ↔ API Gateway (solicitudes API, tokens) (Flujo de datos)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
12	T-02 [Crítico] Manipulación de monto o destino en tránsito	Tampering / Manipulación	Crítica	Abierto	12	Un atacante altera parámetros de la transacción entre la app y el API Gateway mediante proxy interceptor o app instrumentada.	C-05 firma de transacción y step-up, C-06 TLS 1.3, pinning y attestation, C-10 seguridad del API Gateway, C-18 antifraude

F3 Gateway → Autenticación (validación de token) (Flujo de datos)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

F4 Autenticación ↔ BD identidades (hashes, perfiles) (Flujo de datos)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

F6 Gateway → Cuentas y Transacciones (consultas, órdenes) (Flujo de datos)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

F7 Cuentas/Transacciones ↔ BD transaccional (Flujo de datos)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

F8 Cuentas/Transacciones → Middleware (mensajes de transacción) (Flujo de datos)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

F9 Middleware ↔ Core bancario (posteo) (Flujo de datos)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

F10 Middleware ↔ Red ACH (mensajes interbancarios) (Flujo de datos)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

F11 Notificaciones → Proveedor OTP (OTP/SMS) (Flujo de datos)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

F12 Autenticación ↔ Proveedor KYC (verificación de identidad) (Flujo de datos)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

F13 Operador → Backoffice (acceso administrativo, VPN + MFA) (Flujo de datos)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

F14a Gateway → Logging (eventos) (Flujo de datos)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

F14b Autenticación → Logging (eventos) (Flujo de datos)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

F14c Cuentas/ Transacciones → Logging (eventos) (Flujo de datos)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

F14d Middleware → Logging (eventos) (Flujo de datos)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

F14e Backoffice → Logging (eventos) (Flujo de datos)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

F14f Logging → Almacén de logs (Flujo de datos)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

F15a Autenticación → Bóveda (solicitud de secretos) (Flujo de datos)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

F15b Cuentas/Transacciones → Bóveda (solicitud de secretos) (Flujo de datos)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

F15c Middleware → Bóveda (solicitud de secretos) (Flujo de datos)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

F16 Logging → Regulador/Auditor (reportes) (Flujo de datos)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

F17 Backoffice → Cuentas/Transacciones (operaciones de soporte) (Flujo de datos)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

F18 Autenticación → Notificaciones (solicitud de OTP) (Flujo de datos)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

F19 Cuentas/Transacciones → Notificaciones (avisos de operación) (Flujo de datos)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

F5 Autenticación ↔ Caché de sesiones (Flujo de datos)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

P5 - Middleware de integración (MQ/ESB) (Proceso)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

P6 - Core bancario (Proceso)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
26	T-16 [Medio] Saturación del core por picos desde canales digitales	Denial of service / Denegación de servicio	Media	Abierto	4	Picos de transacciones desde los canales saturan el core bancario.	C-09 rate limiting, C-11 segmentación, C-20 colas, circuit breakers y DR

P7 - Servicio de Notificaciones (Proceso)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

P8 - Backoffice / Administración (Proceso)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
14	T-06 [Alto] Abuso de privilegios por insider sin doble aprobación	Elevation of privilege / Elevación de privilegios	Alta	Abierto	8	Un usuario interno con roles amplios altera saldos o extrae datos desde el backoffice sin doble aprobación.	C-04 autorización por objeto y función, C-14 PAM, segregación de funciones y doble aprobación, C-17 SIEM/UEBA

P9 - Monitoreo y logging (SIEM) (Proceso)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
15	T-09 [Alto] Logs sin integridad: negación de operaciones	Repudiation / Repudiación	Alta	Abierto	6	Registros modificables o sin correlación permiten negar operaciones y dificultan probar el fraude.	C-16 logging centralizado inmutable con ID de correlación

D1 - BD de identidades (Dispositivo de almacenamiento)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
27	T-18 [Medio] Hashes de contraseña expuestos con algoritmo débil	Information disclosure / Brecha de información	Media	Abierto	3	Ante una filtración de la BD, un algoritmo de hash débil permite recuperar contraseñas.	C-07 cifrado en reposo y gestión de llaves (hash robusto)

D2 - BD transaccional (Dispositivo de almacenamiento)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
13	T-05 [Alto] Inyección SQL y exfiltración masiva	Information disclosure / Brecha de información	Alta	Abierto	8	Una inyección SQL o acceso indebido permite extraer saldos, movimientos y PII de la base transaccional.	C-03 consultas parametrizadas, C-07 cifrado y tokenización, C-11 segmentación, C-12 hardening y pruebas SAST/DAST

D3 - Caché de sesiones (Dispositivo de almacenamiento)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
29	T-22 [Bajo] Agotamiento de caché y caída de sesiones	Denial of service / Denegación de servicio	Baja	Abierto	2	El agotamiento de la caché invalida sesiones activas.	C-20 resiliencia y dimensionamiento

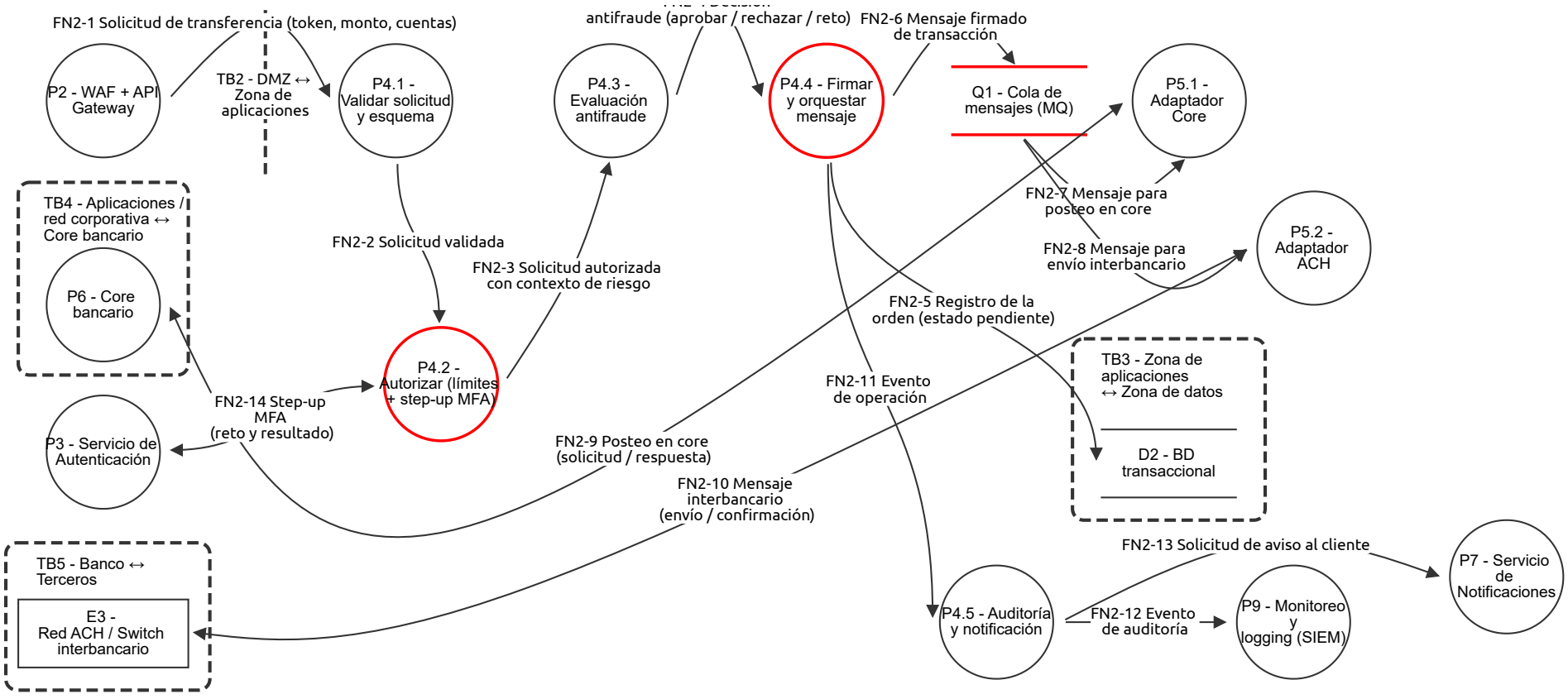
D4 - Almacén de logs (Dispositivo de almacenamiento)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
23	T-13 [Alto] Datos sensibles en logs en texto claro	Information disclosure / Brecha de información	Alta	Abierto	6	Los logs almacenan PAN, tokens o PII sin enmascarar y son accesibles a más personal del necesario.	C-16 logging con enmascaramiento y control de acceso

D5 - Bóveda de secretos / HSM (Dispositivo de almacenamiento)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
24	T-14 [Alto] Secretos expuestos en repositorios, variables o imágenes	Information disclosure / Brecha de información	Alta	Abierto	8	Llaves, credenciales o API keys quedan fuera de la bóveda y permiten compromiso lateral.	C-07 gestión de llaves, C-13 bóveda, rotación y escaneo de secretos

DFD Nivel 2 - Transferencias



DFD Nivel 2 - Transferencias

P4.1 - Validar solicitud y esquema (Proceso)

Descripción: Valida formato, esquema y reglas de negocio de la orden recibida del Gateway

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

P4.2 - Autorizar (límites + step-up MFA) (Proceso)

Descripción: Verifica propiedad de la cuenta, límites y exige segundo factor según riesgo.

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
31	T-03 [Crítico] BOLA/IDOR: operar sobre cuentas ajenas	Tampering / Manipulación	Crítica	Abierto	12	Un usuario autenticado sustituye el identificador de la cuenta origen y opera sobre cuentas de terceros porque el servidor no valida la propiedad del objeto.	C-04 autorización por objeto y función, C-08 OAuth 2.0/OIDC, C-17 SIEM/UEBA, C-18 antifraude
32	T-04 [Crítico] Evasión de step-up y límites (BFLA, endpoints legacy)	Elevation of privilege / Elevación de privilegios	Crítica	Abierto	9	Se invocan endpoints antiguos o se manipulan indicadores para omitir el segundo factor y los límites.	C-04 autorización, C-05 firma de transacción y step-up, C-08 OAuth 2.0/OIDC, C-10 seguridad del API Gateway e inventario de versiones

P4.3 - Evaluación antifraude (Proceso)

Descripción: Calcula el puntaje de riesgo de la operación y decide aprobar, rechazar o retar.

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

P4.4 - Firmar y orquestar mensaje (Proceso)

Descripción: Firma la orden, la registra y la publica en la cola para su procesamiento.

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
33	T-17 [Medio] Cliente niega una transferencia (sin firma de transacción)	Repudiation / Repudiación	Media	Abierto	4	Sin firma de transacción verificable, el cliente puede negar haber ordenado la operación.	C-05 firma de transacción y step-up

P4.5 - Auditoría y notificación (Proceso)

Descripción: Registra el evento y solicita el aviso al cliente.

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

P5.1 - Adaptador Core (Proceso)

Descripción: Traduce y envía la orden al core bancario.

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

P5.2 - Adaptador ACH (Proceso)

Descripción: Traduce y envía la orden a la red interbancaria.

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

Q1 - Cola de mensajes (MQ) (Dispositivo de almacenamiento)

Descripción: Cola de transacciones entre canales digitales, core y ACH.

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
34	T-07 [Alto] Manipulación o repetición (replay) de mensajes en la cola	Tampering / Manipulación	Alta	Abierto	8	Se inyectan, alteran o repiten mensajes porque el canal no autentica ni firma.	C-11 segmentación, C-15 mensajería firmada, idempotencia y anti-replay

D2 - BD transaccional (Dispositivo de almacenamiento)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

P2 - WAF + API Gateway (Proceso)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

FN2-1 Solicitud de transferencia (token, monto, cuentas) (Flujo de datos)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

FN2-2 Solicitud validada (Flujo de datos)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

FN2-3 Solicitud autorizada con contexto de riesgo (Flujo de datos)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

FN2-4 Decisión antifraude (aprobar / rechazar / reto) (Flujo de datos)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

FN2-5 Registro de la orden (estado pendiente) (Flujo de datos)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

FN2-6 Mensaje firmado de transacción (Flujo de datos)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

FN2-7 Mensaje para posteo en core (Flujo de datos)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

FN2-8 Mensaje para envío interbancario (Flujo de datos)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

FN2-9 Posteo en core (solicitud / respuesta) (Flujo de datos)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

FN2-10 Mensaje interbancario (envío / confirmación) (Flujo de datos)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

FN2-11 Evento de operación (Flujo de datos)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

FN2-12 Evento de auditoría (Flujo de datos)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

FN2-13 Solicitud de aviso al cliente (Flujo de datos)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

FN2-14 Step-up MFA (reto y resultado) (Flujo de datos)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

P3 - Servicio de Autenticación (Proceso)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

P6 - Core bancario (Proceso)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

P7 - Servicio de Notificaciones (Proceso)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

P9 - Monitoreo y logging (SIEM) (Proceso)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

E3 - Red ACH / Switch interbancario (Actor)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones